Insper

Analise de Risco

Prof. Dr. Rodolfo Avelino

Risco é a incerteza nos objetivos.

Fonte: ISO 31000

Fonte de risco

Elemento que individualmente ou combinado, tem potencial para dar origem ao risco.

Fonte: ISO 31.000

A ameaça sempre existe, com maior ou menor probabilidade de ocorrer.

Fonte: DARYUS Consultoria

Vulnerabilidade

- Falta ou falha de controles.
- O quão vulneravel está frente à(s) ameaça(s)

Fonte: DARYUS Consultoria

3.4
fonte de risco
elemento que, individualmente ou combinado, tem o potencial para dar origem ao *risco* (3.1)

3.5
evento
ocorrência ou mudança em um conjunto específico de circunstâncias

Nota 1 de entrada: Um evento pode consistir em uma ou mais ocorrências e pode ter várias causas e várias *consequências* (3.6).

Nota 2 de entrada: Um evento pode também ser algo que é esperado, mas não acontece, ou algo que não é esperado, mas acontece.

Nota 3 de entrada: Um evento pode ser uma fonte de risco.

3.6
consequência
resultado de um *evento* (3.5) que afeta os objetivos

Nota 1 de entrada: Uma consequência pode ser certa ou incerta e pode ter efeitos positivos ou negativos, diretos ou indiretos, nos objetivos.

Nota 2 de entrada: As consequências podem ser expressas qualitativa ou quantitativamente.

Nota 3 de entrada: Qualquer consequência pode escalar por meio de efeitos cascata e cumulativos.

Fonte: ABNT ISO/IEC 31000:2018 (pg2)

3.7
probabilidade
chance de algo acontecer

Nota 1 de entrada: Na terminologia de *gestão de riscos* (3.2), a palavra "probabilidade" é utilizada para referir-se à chance de algo acontecer, não importando se definida, medida ou determinada, ainda que objetiva ou subjetivamente, qualitativa ou quantitativamente, e se descrita utilizando-se termos gerais ou matemáticos (como probabilidade ou frequência durante um determinado período de tempo).

Nota 2 de entrada: O termo em inglês "*likelihood*" não tem um equivalente direto em algumas línguas; em vez disso, o equivalente do termo "*probability*" é frequentemente utilizado. Entretanto, em inglês, "*probability*" é muitas vezes interpretado estritamente como uma expressão matemática. Portanto, na terminologia de gestão de riscos, convém que "*likelihood*" seja utilizado com a mesma ampla interpretação que o termo "*probability*" tem em muitos outros idiomas, além do inglês.

3.8
controle
medida que mantém e/ou modifica o *risco* (3.1)

Nota 1 de entrada: Controles incluem, mas não estão limitados a, qualquer processo, política, dispositivo, prática, ou outras condições e/ou ações que mantêm e/ou modificam o risco.

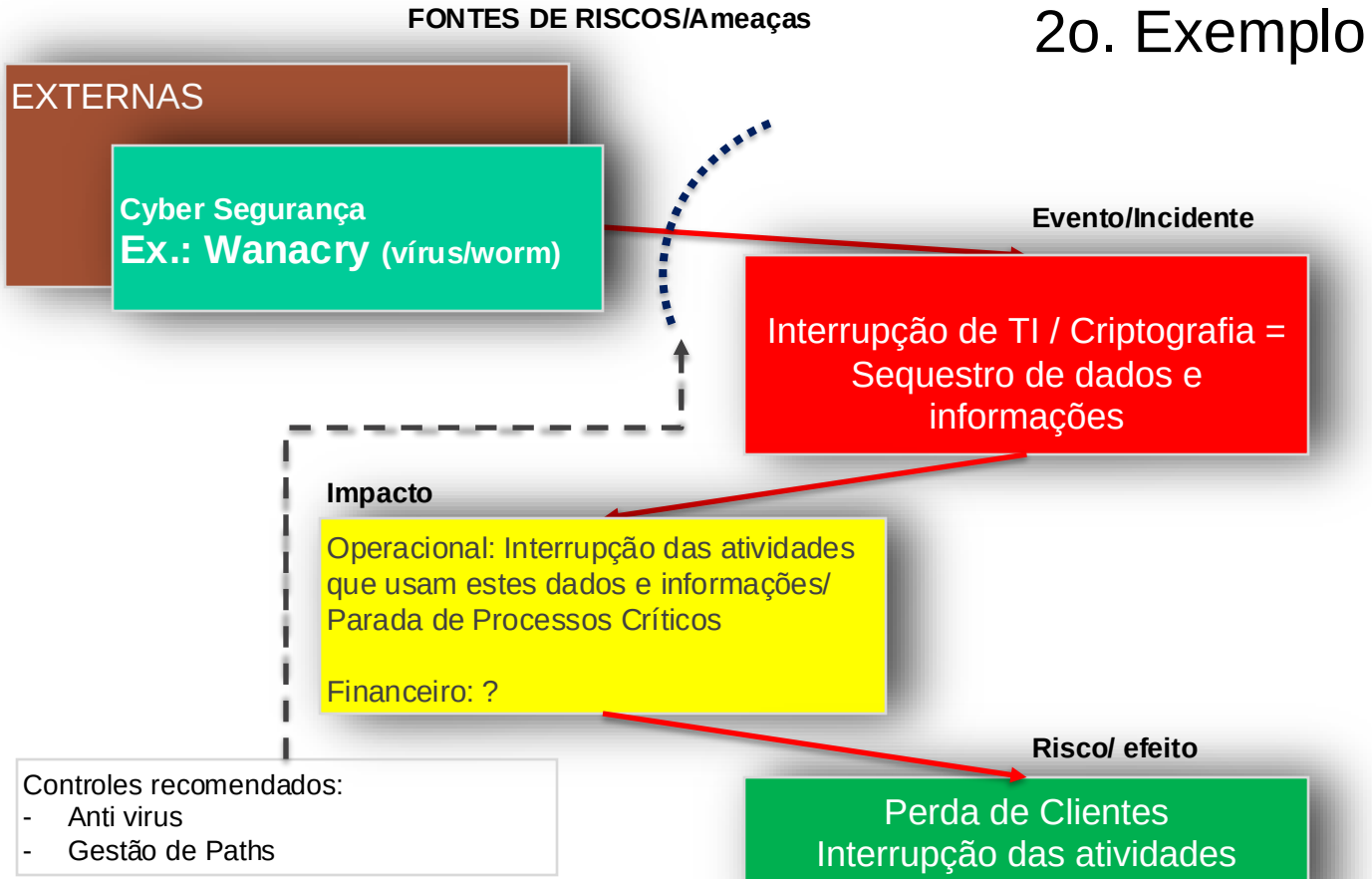
Nota 2 de entrada: Controles podem nem sempre exercer o efeito modificador pretendido ou presumido.

Fonte: ABNT ISO/IEC 31000:2018 (pg3)

3.4
fonte de risco
elemento que, individualmente ou combinado, tem o potencial para dar origem ao *risco* (3.1)

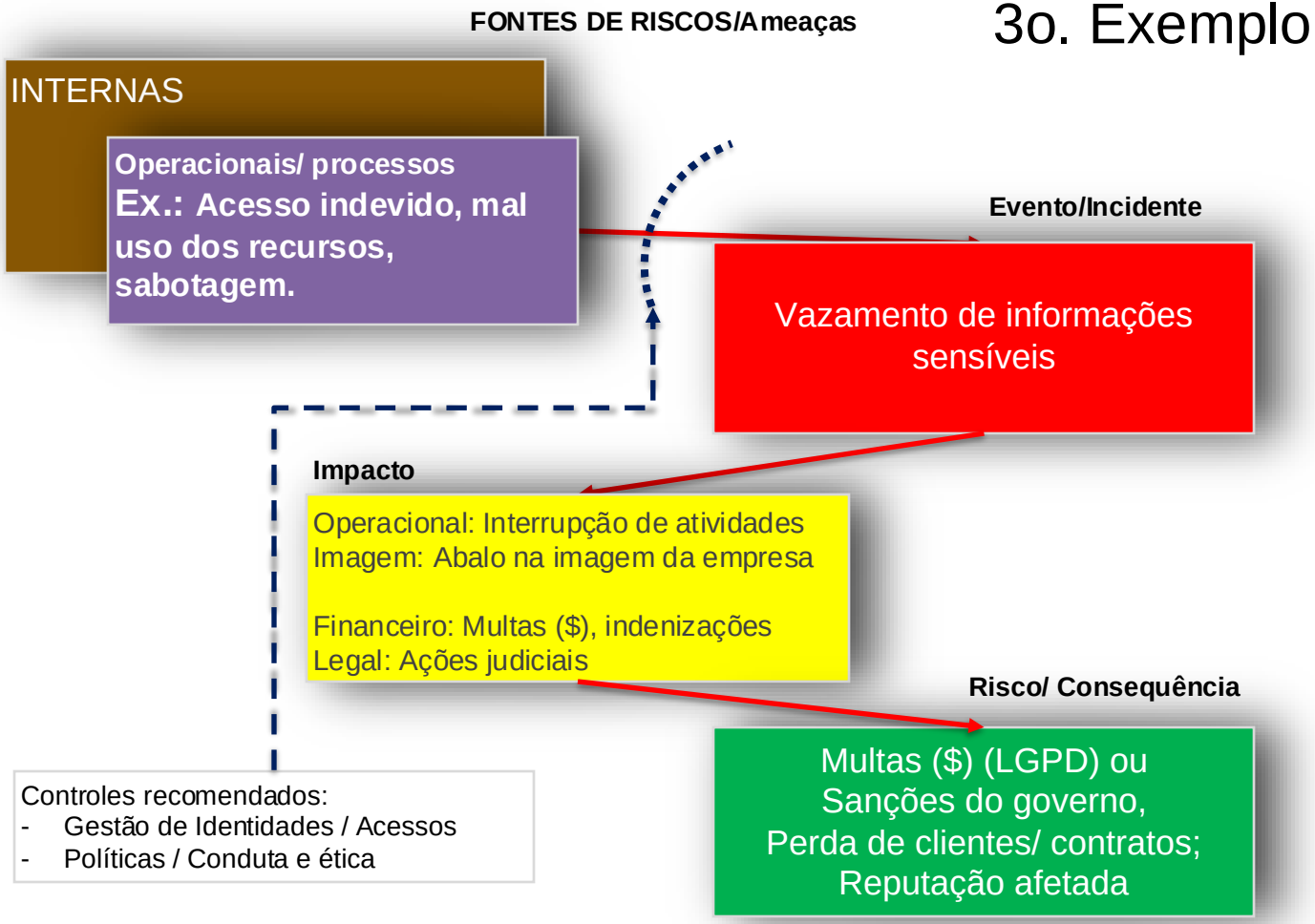
Naturais	Humanas	Tecnológicas	Político-Econômicas	Físicas
Chuva	Roubo ou Furto	Falhas de TI	Crise de Energia	Fogo/ incêndio
Enchente (externo)	Distúrbio Civil	Cyber ameaça	Crise Política	Desabamento
Terremoto	Greve/ manifestação	Vírus de computador	Variação cambial abrupta	Queda de aeronave
Inundação (interno)	Sabotagem	Interrupção de link	Sanções e/ou intervenções	Acidente de transito
Raio	Vazamento involuntário de dados e informações	Interrupção de serviço de TIC	Crise de Segurança Pública	Acidente ferroviário
Tempestades	Vandalismo	Erros de tecnologias	Guerras ou conflitos	Explosão
Furacão	Zona de alta criminalidade	Obsolescência	Imigração involuntária	Vazamentos Tóxicos
Avalanche	Vazamento intencional de dados e informações	Fraudes cibernéticas	Crise de Água/ Falta	Vazamentos químicos
Erupções/ vulcões	Erros intencionais	Roubo de dados /identidades	Instabilidade governamental/ econômica	Contaminação

2o. Exemplo



**WannaCry: o primeiro ransomworm na indústria de Cibersegurança. (fonte: internet)*

3o. Exemplo


FONTES DE RISCOS/Ameaças
INTERNAS
Operacionais/ processos
Ex.: Acesso indevido, mal uso dos recursos, sabotagem.
Evento/Incidente
Vazamento de informações sensíveis
Impacto
Operacional: Interrupção de atividades
Imagem: Abalo na imagem da empresa
Financeiro: Multas ($), indenizações
Legal: Ações judiciais
Risco/ Consequência
Multas ($) (LGPD) ou
Sanções do governo,
Perda de clientes/ contratos;
Reputação afetada
Controles recomendados:
- Gestão de Identidades / Acessos
- Políticas / Conduta e ética

3.8
controle
medida que mantém e/ou modifica o *risco* (3.1)

Nota 1 de entrada: Controles incluem, mas não estão limitados a, qualquer processo, política, dispositivo, prática, ou outras condições e/ou ações que mantêm e/ou modificam o risco.

Nota 2 de entrada: Controles podem nem sempre exercer o efeito modificador pretendido ou presumido.

Tecnológicos/ dispositivos	Processuais	De Gestão / Administração	Político-Econômicos	Segurança Empresarial
Firewall	Dupla verificação	Política de Segurança	Leis/ Constituição	Portas
IDS	Classificar a informação	Termo de Conduta e ética	Agencias reguladores	Catracas
Antivírus	Mesa limpa	Indicadores (KRI)	Forças de defesa	CIPA
Alta Disponibilidade	Catracas	Comitês	Defesa Civil	Brigada de incêndio
Backup	Controle de Qualidade	Seguros	Bombeiros	Extintores
No break / Geradores	Fluxo de autorização	Plano de Continuidade	Fiscalização	Vigilantes
Controle de Acesso lógico	Compliance	Educação / Conscientização	Multas/ punições	Controle de Acesso físico
Criptografia	Análise crítica/ manutenções	Auditorias	Tributação/ impostos	CFTV

3.7
probabilidade
chance de algo acontecer

ATENÇÃO!

VULNERABILIDADE
Falta ou falha de controles. O quão vulneravel está frente à(s) ameaça(s),considerando os controles.

Tecnológicos/ dispositivos	Processuais	De Gestão / Administração	Político-Econômicos	Segurança Empresarial
Falta ou falha de Firewall	Sem dupla verificação	Não há Política de Segurança	Leis/ Constituição frágeis ou insuficientes	Não há Portas
Falta de segurança da informação	Não há Classificar a informação	Não há Termo de Conduta e ética	Agencias reguladores sem poder	Falhas nas Catracas

3.1
risco
efeito da incerteza nos objetivos

Nota 1 de entrada: Um efeito é um desvio em relação ao esperado. Pode ser positivo, negativo ou ambos, e pode abordar, criar ou resultar em oportunidades e ameaças.

Risco Positivo	Risco Negativo	Oportunidades
Antecipação de término de contrato	Perda de Contratos	Renovação com preços novos mais altos
Estudo de novos mercados potenciais	Perda de Mercado	Reavaliar mercado e oportunidades para produtos e serviços
Redução de custos e despesas	Interrupção de planta fabril pelo governo	Renegociação com fornecedores/credores
Demonstrar capacidade de gerenciamento de crise	Exposição negativa na mídia / Executivos / Corrupção	Readequação de liderança / Redução de custos/ despesas
Conscientização maior das necessidades de investimentos em defesa cibernética	Interrupção por cyber incidente	Investimentos e melhorias priorizadas
Renovação de equipes/ novos modelos de gestão e administração	Crise financeira severa/ demissões	Planos demissionais / ajustes de equipes/ redução de despesas
Maior conscientização e investimento em proteção	Multa de LGPD	Melhoria global /respeito a privacidade/ proteção ao patrimônio/ informação



Fonte: ABNT ISO/IEC 27005:2019

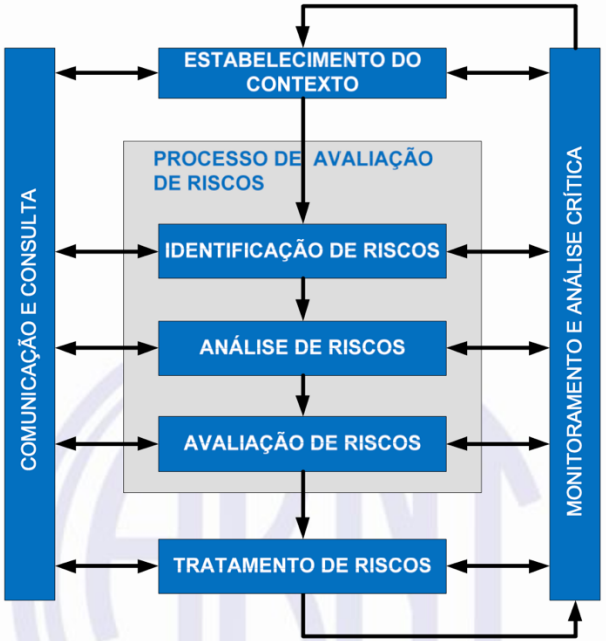


Figura 1 – O processo de gestão de riscos

A Figura 2 apresenta como este documento é aplicado ao processo de gestão de riscos.

Fonte: ABNT ISO/IEC 27005:2019

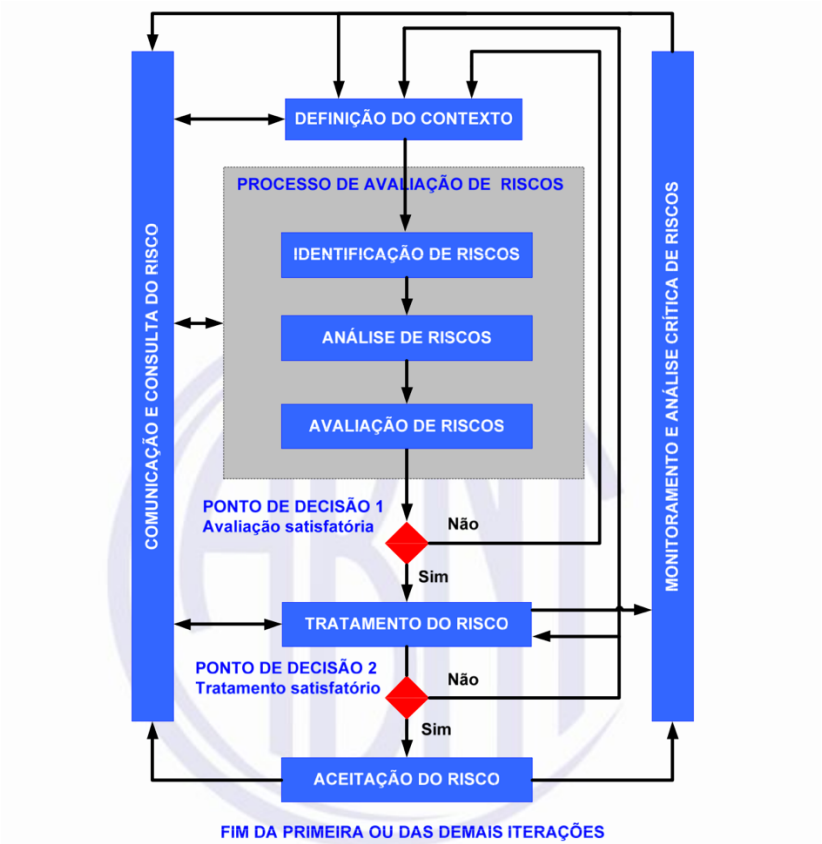


Figura 2 – Processo de gestão de riscos de segurança da informação

Fonte: ABNT ISO/IEC 27005:2019

O NIST (National Institute of Standards and Technology) define em SP 800-30 recomendações e um guia para o gerenciamento de riscos para sistemas de Tecnologia da Informação.
Dentre diversas recomendações, o NIST recomenda o seguinte sequenciamento de ações na avaliação de um risco:

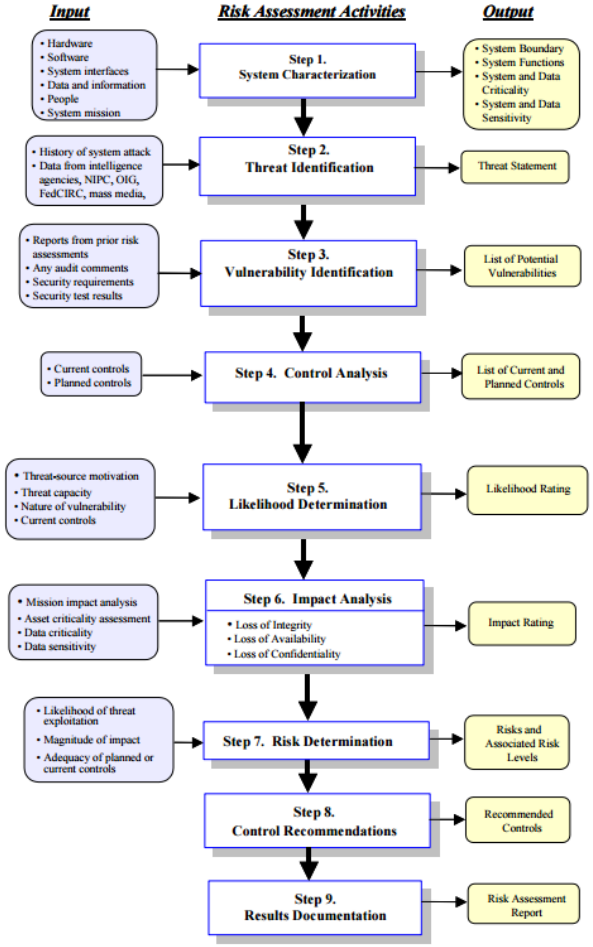


Figure 3-1. Risk Assessment Methodology Flowchart

Tipo	Ameaças	Origem
Dano físico	Fogo	A, I, N
	Água	A, I, N
	Poluição	A, I, N
	Acidente grave	A, I, N
	Destruição de equipamento ou mídia	A, I, N
	Poeira, corrosão, congelamento	A, I, N
Eventos naturais	Fenômeno climático	N
	Fenômeno sísmico	N
	Fenômeno vulcânico	N
	Fenômeno meteorológico	N
	Inundação	N
Paralisação de serviços essenciais	Falha do ar-condicionado ou do sistema de suprimento de água	A, I
	Interrupção do suprimento de energia	A, I, N
	Falha do equipamento de telecomunicação	A, I
Distúrbio causado por radiação	Radiação eletromagnética	A, I, N
	Radiação térmica	A, I, N
	Pulsos eletromagnéticos	A, I, N

A-cidental, I-ntencional e N-atural

Fonte: ABNT ISO/IEC 27005:2019 – ANEXO C – Exemplos de ameaças comuns

Tipo	Ameaças	Origem
Comprometimento da informação	Interceptação de sinais de interferência comprometedores	I
	Espionagem à distância	I
	Escuta não autorizada	I
	Furto de mídia ou documentos	I
	Furto de equipamentos	I
	Recuperação de mídia reciclada ou descartada	I
	Divulgação indevida	A, I
	Dados de fontes não confiáveis	A, I
	Alteração do *hardware*	I
	Alteração do *software*	A, I
	Determinação da localização	I
Falhas técnicas	Falha de equipamento	A
	Defeito de equipamento	A
	Saturação do sistema de informação	A, I
	Defeito de *software*	A
	Violação das condições de uso do sistema de informação que possibilitam sua manutenção	A, I
Ações não autorizadas	Uso não autorizado de equipamento	I
	Cópia ilegal de *software*	I
	Uso de cópias de *software* falsificadas ou ilegais	A, I
	Comprometimento dos dados	I
	Processamento ilegal de dados	I
Comprometimento de funções	Erro durante o uso	A
	Abuso de direitos	A, I
	Forjamento de direitos	I
	Repúdio de ações	I
	Indisponibilidade de recursos humanos	A, I, N

A-cidental, I-ntencional e N-atural

Fonte: ABNT ISO/IEC 27005:2019 – ANEXO C – Exemplos de ameaças comuns

Origem das Ameaças	Motivação	Possíveis Consequências
Hacker, cracker	Desafio Ego Rebeldia *Status* Dinheiro	• *Hacking* • Engenharia social • Invasão de sistemas, infiltrações e entradas não autorizadas • Acesso não autorizado ao sistema
Criminoso digital	Destruição de informações Divulgação ilegal de informações Ganho monetário Alteração de dados não autorizada	• Crime digital (por exemplo, perseguição no mundo digital) • Ato fraudulento (por exemplo, reutilização indevida de credenciais e dados transmitidos, fazer-se passar por uma outra pessoa, interceptação) • Suborno por informação • *Spoofing* (fazer-se passar por outro) • Invasão de sistemas
Terrorista	Chantagem Destruição Exploração Vingança Ganho político Cobertura da mídia	• Bomba/terrorismo • Guerra de informação • Ataque a sistemas (por exemplo, ataque distribuído de negação de serviço). • Invasão de sistema • Alteração do sistema
Espionagem industrial (serviços de inteligência, empresas, governos estrangeiros, outros grupos de interesse ligados ao governo)	Vantagem competitiva Espionagem econômica	• Garantir a vantagem de um posicionamento defensivo • Garantir uma vantagem política • Exploração econômica • Furto de informação • Violação da privacidade das pessoas • Engenharia social • Invasão de sistema • Acesso não autorizado ao sistema (acesso a informação restrita, de propriedade exclusiva, e/ou relativa à tecnologia)

Fonte: ABNT ISO/IEC 27005:2019 – ANEXO C – Exemplos de ameaças comuns

Origem das Ameaças	Motivação	Possíveis Consequências
Pessoal interno (funcionários mal treinados, insatisfeitos, mal intencionados, negligentes, desonestos ou dispensados)	Curiosidade Ego Obtenção de informações úteis para serviços de inteligência Ganho monetário Vingança Erros e omissões não intencionais (por exemplo, erro na entrada de dados, erro de programação)	• Agressão a funcionário • Chantagem • Vasculhar informação de propriedade exclusiva • Uso impróprio de recurso computacional • Fraude e furto • Suborno por informação • Entrada de dados falsificados ou corrompidos • Interceptação • Código malicioso (por exemplo: vírus, bomba lógica, Cavalo de Tróia) • Venda de informações pessoais • Defeitos (“*bugs*”) no sistema • Invasão de sistemas • Sabotagem de sistemas • Acesso não autorizado ao sistema

Fonte: ABNT ISO/IEC 27005:2019 – ANEXO C – Exemplos de ameaças comuns

Tipos	Exemplos de vulnerabilidades	Exemplos de ameaças
Hardware	Manutenção insuficiente/Instalação defeituosa de mídia de armazenamento	Violação das condições de uso do sistema de informação que possibilitam sua manutenção
	Falta de uma rotina de substituição periódica	Destruição de equipamento ou mídia
	Sensibilidade à umidade, poeira, sujeira	Poeira, corrosão, congelamento
	Sensibilidade à radiação eletromagnética	Radiação eletromagnética
	Inexistência de um controle eficiente de mudança de configuração	Erro durante o uso
	Sensibilidade a variações de voltagem	Interrupção do suprimento de energia
	Sensibilidade a variações de temperatura	Fenômeno meteorológico
	Armazenamento não protegido	Furto de mídia ou documentos
	Falta de cuidado durante o descarte	Furto de mídia ou documentos
	Realização não controlada de cópias	Furto de mídia ou documentos

Fonte: ABNT ISO/IEC 27005:2019 – ANEXO C – Exemplos de vulnerabilidades

Tipos	Exemplos de vulnerabilidades	Exemplos de ameaças
Software	Procedimentos de teste de *software* insuficientes ou inexistentes	Abuso de direitos
	Falhas conhecidas no *software*	Abuso de direitos
	Não execução do "*logout*" ao se deixar uma estação de trabalho desassistida	Abuso de direitos
	Descarte ou reutilização de mídia de armazenamento sem a execução dos procedimentos apropriados de remoção dos dados	Abuso de direitos
	Inexistência de uma trilha de auditoria	Abuso de direitos
	Atribuição errônea de direitos de acesso	Abuso de direitos
	Software amplamente distribuído	Comprometimento dos dados
	Utilizar programas aplicativos com um conjunto errado de dados (referentes a um outro período)	Comprometimento dos dados
	Interface de usuário complicada	Erro durante o uso
	Documentação inexistente	Erro durante o uso
	Configuração de parâmetros incorreta	Erro durante o uso
	Datas incorretas	Erro durante o uso
	Inexistência de mecanismos de autenticação e identificação como, por exemplo, para a autenticação de usuários	Forjamento de direitos
	Tabelas de senhas desprotegidas	Forjamento de direitos
	Gerenciamento de senhas mal feito	Forjamento de direitos
	Serviços desnecessários permanecem habilitados	Processamento ilegal de dados
	Software novo ou imaturo	Defeito de *software*
	Especificações confusas ou incompletas para os desenvolvedores	Defeito de *software*
	Inexistência de um controle eficaz de mudança	Defeito de *software*
	Download e uso não controlado de *software*	Alteração do *software*
	Inexistência de cópias de segurança ("*back-up*")	Alteração do *software*
	Inexistência de mecanismos de proteção física no prédio, portas e janelas	Furto de mídia ou documentos
	Inexistência de relatórios de gerenciamento	Uso não autorizado de equipamento

Fonte: ABNT ISO/IEC 27005:2019 – ANEXO C – Exemplos de vulnerabilidades

Tipos	Exemplos de vulnerabilidades	Exemplos de ameaças
Rede	Inexistência de evidências que comprovem o envio ou o recebimento de mensagens	Repúdio de ações
	Linhas de comunicação desprotegidas	Escuta não autorizada
	Tráfego sensível desprotegido	Escuta não autorizada
	Junções de cabeamento mal feitas	Falha do equipamento de telecomunicação
	Ponto único de falha	Falha do equipamento de telecomunicação
	Não identificação e não autenticação do emissor e do receptor	Forjamento de direitos
	Arquitetura insegura da rede	Espionagem à distância
	Transferência de senhas em claro	Espionagem à distância
	Gerenciamento de rede inadequado (quanto à flexibilidade de roteamento)	Saturação do sistema de informação
	Conexões de redes públicas desprotegidas	Uso não autorizado de equipamento
Recursos humanos	Ausência de recursos humanos	Indisponibilidade de recursos humanos
	Procedimentos de recrutamento inadequados	Destruição de equipamento ou mídia
	Treinamento insuficiente em segurança	Erro durante o uso
	Uso incorreto de *software* e *hardware*	Erro durante o uso
	Falta de conscientização em segurança	Erro durante o uso
	Inexistência de mecanismos de monitoramento	Processamento ilegal de dados
	Trabalho não supervisionado de pessoal de limpeza ou de terceirizados	Furto de mídia ou documentos
	Inexistência de políticas para o uso correto de meios de telecomunicação e de troca de mensagens	Uso não autorizado de equipamento

Fonte: ABNT ISO/IEC 27005:2019 – ANEXO C – Exemplos de vulnerabilidades

Local ou instalações	Uso inadequado ou sem os cuidados necessários dos mecanismos de controle do acesso físico a prédios e aposentos	Destruição de equipamento ou mídia
	Localização em área suscetível a inundações	Inundação
	Fornecimento de energia instável	Interrupção do suprimento de energia
	Inexistência de mecanismos de proteção física no prédio, portas e janelas	Furto de equipamentos

Fonte: ABNT ISO/IEC 27005:2019 – ANEXO C – Exemplos de vulnerabilidades

Tipos	Exemplos de vulnerabilidades	Exemplos de ameaças
Organização	Inexistência de um procedimento formal para o registro e a remoção de usuários	Abuso de direitos
	Inexistência de processo formal para a análise crítica dos direitos de acesso (supervisão)	Abuso de direitos
	Provisões (relativas à segurança) insuficientes ou inexistentes, em contratos com clientes e/ou terceiros	Abuso de direitos
	Inexistência de procedimento de monitoramento das instalações de processamento de informações	Abuso de direitos
	Inexistência de auditorias periódicas (supervisão)	Abuso de direitos
	Inexistência de procedimentos para a identificação, análise e avaliação de riscos	Abuso de direitos
	Inexistência de relatos de falha nos arquivos ("*logs*") de auditoria das atividades de administradores e operadores	Abuso de direitos
	Resposta inadequada do serviço de manutenção	Violação das condições de uso do sistema de informação que possibilitam sua manutenção
	Acordo de nível de serviço (SLA - da sigla do termo em inglês) inexistente ou insuficiente	Violação das condições de uso do sistema de informação que possibilitam sua manutenção
	Inexistência de procedimento de controle de mudanças	Violação das condições de uso do sistema de informação que possibilitam sua manutenção
	Inexistência de um procedimento formal para o controle da documentação do SGSI	Comprometimento dos dados
	Inexistência de um procedimento formal para a supervisão dos registros do SGSI	Comprometimento dos dados
	Inexistência de um processo formal para a autorização das informações disponíveis publicamente	Dados de fontes não confiáveis
	Atribuição inadequada das responsabilidades pela segurança da informação	Repúdio de Ações
	Inexistência de um plano de continuidade	Falha de equipamento
	Inexistência de política de uso de correspondência eletrônica (*e-mail*)	Erro durante o uso
	Inexistência de procedimentos para a instalação de *software* em sistemas operacionais	Erro durante o uso
	Ausência de registros nos arquivos de auditoria ("*logs*") de administradores e operadores	Erro durante o uso
	Inexistência de procedimentos para a manipulação de informações classificadas	Erro durante o uso

Fonte: ABNT ISO/IEC 27005:2019 – ANEXO C – Exemplos de vulnerabilidades

Tipos	Exemplos de vulnerabilidades	Exemplos de ameaças
Organização	Ausência das responsabilidades ligadas à segurança da informação nas descrições de cargos e funções	Erro durante o uso
	Provisões (relativas à segurança) insuficientes ou inexistentes, em contratos com funcionários	Processamento ilegal de dados
	Inexistência de um processo disciplinar no caso de incidentes relacionados à segurança da informação	Furto de equipamentos
	Inexistência de uma política formal sobre o uso de computadores móveis	Furto de equipamentos
	Inexistência de controle sobre ativos fora das dependências	Furto de equipamentos
	Política de mesas e telas limpas ("*clear desk and clear screen*") inexistente ou insuficiente	Furto de mídia ou documentos
	Inexistência de autorização para as instalações de processamento de informações	Furto de mídia ou documentos
	Inexistência de mecanismos estabelecidos para o monitoramento de violações da segurança	Furto de mídia ou documentos
	Inexistência de análises críticas periódicas por parte da direção	Uso não autorizado de equipamento
	Inexistência de procedimentos para o relato de fragilidades ligadas à segurança	Uso não autorizado de equipamento
	Inexistência de procedimentos para garantir a conformidade com os direitos de propriedade intelectual	Uso de cópias de *software* falsificadas ou ilegais

Fonte: ABNT ISO/IEC 27005:2019 – ANEXO C – Exemplos de vulnerabilidades

Tratamento de riscos

Mitigar e/ou Aceitar e/ou Transferir e/ou Evitar

Como Tratar o Risco?

(MATE ou MATA)

Mitigar (Mitigate/control) – implementar controles ou práticas de controles para diminuir o risco a um nível aceitável, ex. Firewall;

Aceitar (Accept) – Risco aceitável ou o investimento no controle não é justificável (valor X perdas, impossibilidades técnicas ou outras, ex. Controle muito mais caro que a possível perda;

Transferir (Transfer/Share) – Diminui-se o risco transferindo ou compartilhando ele com provedores ou terceiros, ex. Seguro ou terceirização (obs.: “O FILHO AINDA É SEU!”);

Evitar (Avoid) – Evita-se o risco se afastando dele ou mudando o processo, local, ativos ou outros, ex.: Mudar o local da sede.

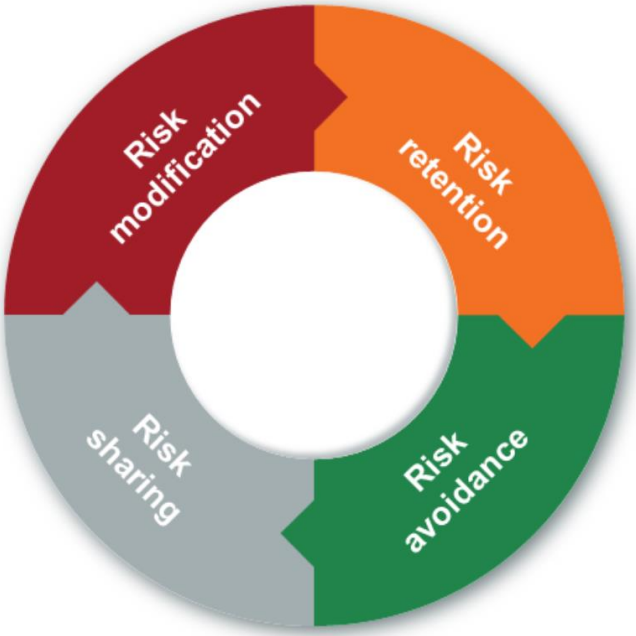
Como Tratar o Risco? (MRSA)

Risk modification

Information security controls selected to reduce the risks

Risk retention

Management decision to take the risk



Risk sharing

Decision to share risks with external parties: insurance or outsourcing

Risk avoidance

Cancellation or modification of an activity or set of activities related to risk

Fonte: ISO 27001 Lead Auditor Course - PECB

Tratamento de Riscos

Quando tratamos diminuímos a PROBABILIDADE DE OCORRER ou a VULNERABILIDADE?

Exercitando:

A Probabilidade, não depende de nós!
A Vulnerabilidade, sim!

Reflita: Quando instalamos para-raios num edifício estamos diminuindo sua vulnerabilidade (exposição) frente à ameaça de RAIOS, portanto, CONTROLES mitigam riscos. A Probabilidade de cair um raio continua a mesma variando sua probabilidade de acordo com a região.

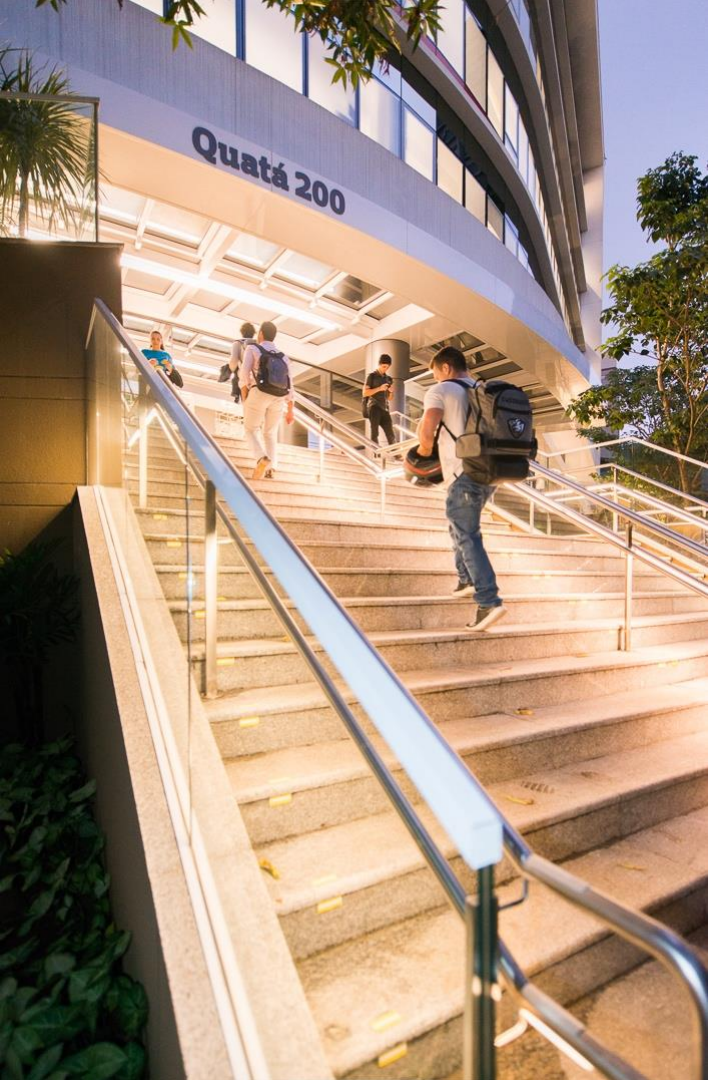
APETITE DE RISCO

É o nível de risco que uma organização está disposta a aceitar enquanto persegue seus objetivos. O Guia ISO 73:2009 define o apetite de risco como sendo a "quantidade e tipo de risco que uma organização está disposta a buscar, manter ou assumir".

Fonte: ISO Guide 73:2009

Definindo a postura do risco

- O erro comum é tratar todos os riscos igualmente.
- Postura reativa
- as organizações devem segmentar a tolerância para diferentes tipos de risco e se concentrar em como e onde gerenciar o risco de maneira eficaz e eficiente.



Revisão

- Risco
- Probabilidade
- Impacto
- Vulnerabilidade
- Consequência



Obrigado

Prof. Rodolfo Avelino